

Security Assessment

A security framework is a set of standards, best practices, and guidelines that help organizations manage and improve their cybersecurity posture. These frameworks provide a systematic approach for identifying vulnerabilities, protecting systems, and responding to security incidents.

The cybersecurity framework developed by the **National Institute of Standards and Technology (NIST)** is widely used to assess and improve security practices. It helps organizations identify weaknesses in their systems and implement appropriate security controls.

The framework consists of five main functions:

- **Identify**

- Understand the organization's assets, systems, and potential risks.
- Identify vulnerabilities in hardware, software, and network configurations.

- **Protect**

- Implement security controls such as firewalls, authentication mechanisms, and encryption to safeguard systems.

- **Detect**

- Monitor systems and networks to detect suspicious activity or potential security incidents.

- **Respond**

- Take appropriate actions to contain and mitigate security incidents.

- **Recover**

- Restore systems and services after a security incident and improve future security practices.

1. **Vulnerability Assessment**

Vulnerability assessment is the process of scanning systems, networks, or applications to identify known security weaknesses and misconfigurations. The goal is to detect vulnerabilities before attackers exploit them. This type of testing focuses on identifying issues such as outdated software, open ports, weak configurations, and missing security patches. Tools such as **OpenVAS** are commonly used to automatically scan systems and generate reports highlighting potential security risks.

2. **Penetration Testing**

Penetration testing involves simulating real-world cyberattacks to exploit identified vulnerabilities and determine how far an attacker could penetrate the system. This testing helps evaluate the effectiveness of security controls and identify weaknesses that could lead to unauthorized access. Security professionals often use tools available in **Kali Linux**, such as **Metasploit Framework** and **Nmap**, to scan targets, identify services, and attempt controlled exploitation of vulnerabilities.

3. **Compliance Testing**

Compliance testing ensures that an organization's systems and security practices follow established security standards and regulatory requirements. This type of testing verifies whether systems are configured according to recommended security guidelines and policies. Organizations often use checklists or benchmarks, such as those provided by the **Center for Internet Security**, to validate system configurations and ensure compliance with security standards. Compliance testing helps organizations maintain regulatory requirements and improve overall security governance.

VAPT Methodology

Objective

The objective of VAPT is to follow a structured and systematic approach to identify, analyze, exploit, and report security vulnerabilities in systems, networks, and applications.

Phases of VAPT

1. Planning

The planning phase involves defining the scope, objectives, and boundaries of the security assessment. It includes identifying the target systems, obtaining necessary permissions, and establishing rules of engagement. Proper planning ensures that the testing process is controlled and does not disrupt normal operations. Tools such as Dradis CE can be used to manage the assessment and document the scope.

2. Discovery (Reconnaissance and Scanning)

In this phase, information about the target system is collected. The goal is to identify active hosts, open ports, running services, and potential vulnerabilities. This phase helps in building a clear understanding of the target environment.

Common tools used include:

- Nmap for network scanning and service detection
- OWASP ZAP for identifying web application vulnerabilities

Typical activities include port scanning, service enumeration, and vulnerability scanning.

3. Attack (Exploitation)

The attack phase involves exploiting the identified vulnerabilities to determine their impact. This simulates real-world cyberattacks in a controlled environment. The goal is to understand how an attacker could gain unauthorized access or escalate privileges.

A commonly used tool in this phase is the Metasploit Framework, which provides a wide range of exploits and payloads.

Activities in this phase include exploiting vulnerabilities, gaining access to systems, and testing the effectiveness of security controls.

4. Reporting

The reporting phase is one of the most important parts of VAPT. All findings from the assessment are documented in a structured report. The report should include details of vulnerabilities, their severity levels, proof of concept (such as screenshots or logs), and recommended mitigation strategies.

Reporting tools and templates from penetration testing platforms can be used to create professional reports.

Security Standards & Compliance

Objective

The objective of security standards and compliance is to ensure that systems and organizations follow established regulations and best practices to protect data, maintain privacy, and reduce security risks.

Security standards and compliance frameworks provide guidelines and rules that organizations must follow to secure their systems and data. These standards help in maintaining confidentiality, integrity, and availability of information while also ensuring legal and regulatory compliance.

Common Security Standards

1) General Data Protection Regulation (GDPR)

GDPR is a regulation designed to protect the personal data and privacy of individuals within the European Union. It requires organizations to handle personal data securely and transparently, and to implement strong data protection measures.

2) Health Insurance Portability and Accountability Act (HIPAA)

HIPAA is a regulation that ensures the protection of sensitive healthcare information. It requires organizations to implement safeguards to secure medical records and patient data from unauthorized access.

3) ISO/IEC 27001

ISO/IEC 27001 is an international standard for managing information security. It provides a framework for establishing, implementing, maintaining, and improving an Information Security Management System (ISMS).

Risk Assessment Basics

Objective

The objective of risk assessment is to prioritize identified vulnerabilities using standardized scoring systems so that critical security issues can be addressed first.

Risk assessment is the process of evaluating vulnerabilities based on their severity, likelihood of exploitation, and potential impact on the system. This helps organizations focus on the most important risks and allocate resources effectively.

CVSS Calculator

The Common Vulnerability Scoring System (CVSS) is an industry-standard method used to measure the severity of vulnerabilities.

- It assigns a score between 0 and 10.
- Higher scores indicate more critical vulnerabilities.

Severity levels are categorized as:

- 0.0 – 3.9 → Low
- 4.0 – 6.9 → Medium
- 7.0 – 8.9 → High

Vapt Task 01

- 9.0 – 10 → Critical

The CVSS score is calculated based on factors such as attack complexity, privileges required, and impact on confidentiality, integrity, and availability. The National Vulnerability Database (NVD) provides an online CVSS calculator for determining these scores.

Risk Matrix

A Risk Matrix is used to categorize vulnerabilities based on two main factors: likelihood and impact.

Impact \ Likelihood	Low	Medium	High
Low Impact	Low	Low	Medium
Medium Impact	Low	Medium	High
High Impact	Medium	High	Critical

This matrix helps in classifying risks into categories such as Low, Medium, High, and Critical.

I. Setup Testing Environment

Objective

To create a controlled lab environment for performing vulnerability assessment on a deliberately vulnerable system.

Tools Used

- Attacker Machine: Kali Linux
- Target Machine: Metasploitable 3
- Virtualization Platform: Oracle VM VirtualBox

Steps Performed

1. Installed Kali Linux as the penetration testing environment.
2. Downloaded Metasploitable 3 from GitHub and deployed it as a virtual machine.
3. Configured both VMs using a **Host-Only Network Adapter** to ensure isolated communication.

Vapt Task 01

4. Verified connectivity between attacker and target using:
ping 192.168.56.103
5. Confirmed the target system was active and reachable.

Outcome

A safe and isolated penetration testing lab was successfully created.

```
metasploitable3-ub1404 login: vagrant
Password:
Last login: Thu Mar 19 06:30:37 UTC 2026 on tty1
Welcome to Ubuntu 14.04.6 LTS (GNU/Linux 3.13.0-170-generic x86_64)

 * Documentation:  https://help.ubuntu.com/
vagrant@metasploitable3-ub1404:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 08:00:27:63:b5:e0 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.103/24 brd 192.168.56.255 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe63:b5e0/64 scope link
        valid_lft forever preferred_lft forever
3: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
    link/ether 02:42:ff:9d:80:10 brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever
    inet6 fe80::42:ffff:fe9d:8010/64 scope link
        valid_lft forever preferred_lft forever
vagrant@metasploitable3-ub1404:~$ _
```

II. Vulnerability Scanning

Objective

To identify open ports, running services, and vulnerabilities in the target system.

Tools Used

- Nmap
- Nikto

Step 1: Network Scanning using Nmap

Vapt Task 01

Command Used

```
nmap -sV --script vuln 192.168.56.103
```

Purpose

- Identify open ports
- Detect service versions
- Discover known vulnerabilities

Step 2: Web Vulnerability Scanning using Nikto

Command Used

```
nikto -h http://192.168.56.103
```

Purpose

- Identify web server misconfigurations
- Detect insecure headers and exposed directories

Outcome

The system was found to have multiple vulnerabilities including:

- SQL Injection
- CSRF vulnerabilities
- Missing security headers
- Outdated software
- Directory indexing enabled

Vapt Task 01

```
(pranav@kali)-[~]
$ nmap -sV --script vuln 192.168.56.103
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-19 12:51 +0530
Nmap scan report for 192.168.56.103
Host is up (0.0014s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      ProFTPD 1.3.5
22/tcp    open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux;
protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.7
|_ http-sql-injection:
|   Possible sqlmap queries:
|   http://192.168.56.103:80/?C=N%3B0%3DD%27%200R%20sqlspider
|   http://192.168.56.103:80/?C=S%3B0%3DA%27%200R%20sqlspider
|   http://192.168.56.103:80/?C=D%3B0%3DA%27%200R%20sqlspider
|   http://192.168.56.103:80/?C=M%3B0%3DA%27%200R%20sqlspider
|_ http-dombased-xss: Couldn't find any DOM based XSS.
|_ http-csrf:
|   Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=192.168.56.10
3
|   Found the following possible CSRF vulnerabilities:
|
|   Path: http://192.168.56.103:80/payroll_app.php
|   Form id:
|   Form action:
|
|   Path: http://192.168.56.103:80/drupal/
|   Form id: user-login-form
|   Form action: /drupal/?q=node&destination=node
|
|   Path: http://192.168.56.103:80/chat/
|   Form id: name
|   Form action: index.php
|_ http-enum:
|   /: Root directory w/ listing on 'apache/2.4.7 (ubuntu)'
|   /phpmyadmin/: phpMyAdmin
|_ /uploads/: Potentially interesting directory w/ listing on 'apache/2.4.7
(ubuntu)'
|_ http-server-header: Apache/2.4.7 (Ubuntu)
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
631/tcp   open  ipp         CUPS 1.7
|_ http-server-header: CUPS/1.7 IPP/2.1
|_ http-enum:
|   /admin.php: Possible admin folder
|   /admin/: Possible admin folder
|   /admin/admin/: Possible admin folder
|   /administrator/: Possible admin folder
|   /adminarea/: Possible admin folder
|   /adminLogin/: Possible admin folder
|   /admin_area/: Possible admin folder
|   /administratorlogin/: Possible admin folder
|   /admin/account.php: Possible admin folder
|   /admin/index.php: Possible admin folder
|   /admin/login.php: Possible admin folder
|   /admin/admin.php: Possible admin folder
|   /admin_area/admin.php: Possible admin folder
```



```
| /adminpanel.jsp: Possible admin folder
| /admin/admin_login.jsp: Possible admin folder
| /admin_login.jsp: Possible admin folder
| /adminLogin.jsp: Possible admin folder
| /admin/adminLogin.jsp: Possible admin folder
| /adminarea/index.jsp: Possible admin folder
| /adminarea/admin.jsp: Possible admin folder
| /adminarea/login.jsp: Possible admin folder
| /administrator/index.jsp: Possible admin folder
| /admincontrol/login.jsp: Possible admin folder
| /admin2.jsp: Possible admin folder
| /admin2/login.jsp: Possible admin folder
| /admin2/index.jsp: Possible admin folder
| /administratorlogin.jsp: Possible admin folder
| /admin1.php: Possible admin folder
| /administr8.asp: Possible admin folder
| /administr8.php: Possible admin folder
| /administr8.jsp: Possible admin folder
| /administr8.aspx: Possible admin folder
| /administr8.cfm: Possible admin folder
| /administr8/: Possible admin folder
| /administer/: Possible admin folder
| /administracao.php: Possible admin folder
| /administracao.asp: Possible admin folder
| /administracao.aspx: Possible admin folder
| /administracao.cfm: Possible admin folder
| /administracao.jsp: Possible admin folder
| /administracion.php: Possible admin folder
| /administracion.asp: Possible admin folder
| /administracion.aspx: Possible admin folder
| /administracion.jsp: Possible admin folder
| /administracion.cfm: Possible admin folder
| /administrators/: Possible admin folder
| /adminpro/: Possible admin folder
| /admins/: Possible admin folder
| /admins.cfm: Possible admin folder
| /admins.php: Possible admin folder
| /admins.jsp: Possible admin folder
| /admins.asp: Possible admin folder
| /admins.aspx: Possible admin folder
| /administracion-sistema/: Possible admin folder
| /admin108/: Possible admin folder
| /admin_cp.asp: Possible admin folder
| /admin/backup/: Possible backup
| /admin/download/backup.sql: Possible database backup
| /robots.txt: Robots file
| /admin/upload.php: Admin File Upload
| /admin/CiscoAdmin.jhtml: Cisco Collaboration Server
| /admin-console/: JBoss Console
| /admin4.nsf: Lotus Domino
| /admin5.nsf: Lotus Domino
| /admin.nsf: Lotus Domino
| /administrator/wp-login.php: Wordpress login page.
| /admin/libraries/ajaxfilemanager/ajaxfilemanager.php: Log1 CMS
| /admin/view/javascript/fckeditor/editor/filemanager/connectors/test.html:
OpenCart/FCKEditor File upload
```

Vapt Task 01

```
OpenCart/FCKeditor File upload
| /admin/includes/tiny_mce/plugins/tinybrowser/upload.php: CompactCMS or B-
Hind CMS/FCKeditor File upload
| /admin/includes/FCKeditor/editor/filemanager/upload/test.html: ASP Simple
Blog / FCKeditor File Upload
| /admin/jscript/upload.php: Lizard Cart/Remote File upload
| /admin/jscript/upload.html: Lizard Cart/Remote File upload
| /admin/jscript/upload.pl: Lizard Cart/Remote File upload
| /admin/jscript/upload.asp: Lizard Cart/Remote File upload
| /admin/environment.xml: Moodle files
| /classes/: Potentially interesting folder
| /es/: Potentially interesting folder
| /helpdesk/: Potentially interesting folder
| /help/: Potentially interesting folder
| /printers/: Potentially interesting folder
|_ http-aspnet-debug: ERROR: Script execution failed (use -d to debug)
| http-slowloris-check:
|   VULNERABLE:
|     Slowloris DOS attack
|     State: LIKELY VULNERABLE
|     IDs: CVE:CVE-2007-6750
|     Slowloris tries to keep many connections to the target web server open and hold
|     them open as long as possible. It accomplishes this by opening connections to
|     the target web server and sending a partial request. By doing so, it starves
|     the http server's resources causing Denial Of Service.
|
|     Disclosure date: 2009-09-17
|     References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
|       http://ha.ckers.org/slowloris/
3000/tcp closed ppp
3306/tcp open  mysql      MySQL (unauthorized)
8080/tcp open  http       Jetty 8.1.7.v20120910
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_ http-dombased-xss: Couldn't find any DOM based XSS.
|_ http-server-header: Jetty(8.1.7.v20120910)
| http-slowloris-check:
|   VULNERABLE:
|     Slowloris DOS attack
|     State: LIKELY VULNERABLE
|     IDs: CVE:CVE-2007-6750
|     Slowloris tries to keep many connections to the target web server open and hold
|     them open as long as possible. It accomplishes this by opening connections to
|     the target web server and sending a partial request. By doing so, it starves
|     the http server's resources causing Denial Of Service.
|
|     Disclosure date: 2009-09-17
|     References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
|       http://ha.ckers.org/slowloris/
|_ http-csrf:
|_ Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=192.168.56.10
```

Vapt Task 01

```
Path: http://192.168.56.103:8080/continuum/security/login.action;jsessi
nid=or4c5202cdko1hwt3c4lyjns4
Form id: loginform
Form action: /continuum/security/login_submit.action;jsessionId=or4c520
cdko1hwt3c4lyjns4

Path: http://192.168.56.103:8080/continuum/security/register.action;jse
sionid=or4c5202cdko1hwt3c4lyjns4
Form id: registerform
Form action: /continuum/security/register_submit.action;jsessionId=or4c
202cdko1hwt3c4lyjns4

Path: http://192.168.56.103:8080/continuum/security/login.action;jsessi
nid=or4c5202cdko1hwt3c4lyjns4
Form id: loginform
Form action: /continuum/security/login_submit.action;jsessionId=or4c520
cdko1hwt3c4lyjns4

Path: http://192.168.56.103:8080/continuum/security/login_submit.action
jsessionid=or4c5202cdko1hwt3c4lyjns4
Form id: loginform
Form action: /continuum/security/login_submit.action;jsessionId=or4c520
cdko1hwt3c4lyjns4

Path: http://192.168.56.103:8080/continuum/security/passwordReset.actio
;jsessionId=or4c5202cdko1hwt3c4lyjns4
Form id: passwordresetform
Form action: /continuum/security/passwordReset_submit.action;jsessionId
or4c5202cdko1hwt3c4lyjns4

Path: http://192.168.56.103:8080/continuum/security/login.action;jsessi
nid=or4c5202cdko1hwt3c4lyjns4
Form id: loginform
Form action: /continuum/security/login_submit.action;jsessionId=or4c520
cdko1hwt3c4lyjns4

Path: http://192.168.56.103:8080/continuum/security/register_submit.act
on;jsessionId=or4c5202cdko1hwt3c4lyjns4
Form id: registerform
Form action: /continuum/security/register_submit.action;jsessionId=or4c
202cdko1hwt3c4lyjns4

Path: http://192.168.56.103:8080/continuum/security/passwordReset_submi
.action;jsessionId=or4c5202cdko1hwt3c4lyjns4
Form id: passwordresetform
Form action: /continuum/security/passwordReset_submit.action;jsessionId
or4c5202cdko1hwt3c4lyjns4
181/tcp closed intermapper
AC Address: 08:00:27:63:B5:E0 (Oracle VirtualBox virtual NIC)
Service Info: Hosts: 127.0.0.1, METASPLOITABLE3-UB1404; OSs: Unix, Linux; CPE
cpe:/o:linux:linux_kernel

Host script results:
_smb-vuln-ms10-054: false
smb-vuln-regsvcs-dos:
VULNERABLE:
Service regsvcs in Microsoft Windows systems vulnerable to denial of servi
```

Vapt Task 01

```
|
|   Path: http://192.168.56.103:8080/continuum/security/passwordReset_submi
t.action;jsessionid=or4c5202cdko1hwt3c4lyjns4
|   Form id: passwordresetform
|_   Form action: /continuum/security/passwordReset_submit.action;jsessionid
=or4c5202cdko1hwt3c4lyjns4
8181/tcp closed intermapper
MAC Address: 08:00:27:63:B5:E0 (Oracle VirtualBox virtual NIC)
Service Info: Hosts: 127.0.0.1, METASPLOITABLE3-UB1404; OSs: Unix, Linux; CPE
: cpe:/o:linux:linux_kernel

Host script results:
|_smb-vuln-ms10-054: false
| smb-vuln-regsvcs-dos:
|   VULNERABLE:
|   Service regsvcs in Microsoft Windows systems vulnerable to denial of servi
ce
|   State: VULNERABLE
|   The service regsvcs in Microsoft Windows 2000 systems is vulnerable to
denial of service caused by a null deference
|   pointer. This script will crash the service if it is vulnerable. This
vulnerability was discovered by Ron Bowes
|   while working on smb-enum-sessions.
|_
|_smb-vuln-ms10-061: false

Service detection performed. Please report any incorrect results at https://n
map.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 348.33 seconds
```

Vapt Task 01

```
(pranav@kali)-[~]
$ nikto -h http://192.168.56.103
- Nikto v2.5.0

+ Target IP: 192.168.56.103
+ Target Hostname: 192.168.56.103
+ Target Port: 80
+ Start Time: 2026-03-19 13:02:52 (GMT5.5)

+ Server: Apache/2.4.7 (Ubuntu)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /: Directory indexing found.
+ Apache/2.4.7 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS .
+ /.: Directory indexing found.
+ /.: Appending './' to a directory allows indexing.
+ //: Directory indexing found.
+ //: Apache on Red Hat Linux release 9 reveals the root directory listing by default if there is no index page.
+ /%2e/: Directory indexing found.
+ /%2e/: Weblogic allows source code or directory listing, upgrade to v6.0 SP 1 or higher. See: http://www.securityfocus.com/bid/2513
+ ///: Directory indexing found.
+ /?PageServices: The remote server may allow directory listings through Web Publisher by forcing the server to show all files via 'open directory browsing'. Web Publisher should be disabled. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0269
+ /?wp-cs-dump: The remote server may allow directory listings through Web Publisher by forcing the server to show all files via 'open directory browsing'. Web Publisher should be disabled. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0269
+ /phpmyadmin/changelog.php: Retrieved x-powered-by header: PHP/5.4.5.
+ /phpmyadmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ //////////////////////////////////////
+ //////////////////////////////////////
+ //////////////////////////////////////
+ //////////////////////////////////////: Directory indexing found.
+ //////////////////////////////////////
+ //////////////////////////////////////
+ //////////////////////////////////////
+ //////////////////////////////////////: Abyss 1.03 reveals directory listing when multiple /'s are requested. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2002-1078
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /phpmyadmin/: phpMyAdmin directory found.
+ /phpmyadmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpmyadmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ 8911 requests: 0 error(s) and 22 item(s) reported on remote host
```

Target Information

- IP Address: 192.168.56.103
- Host Status: Active

Open Ports and Services

Port	Service	Version
21	FTP	ProFTPD 1.3.5
22	SSH	OpenSSH 6.6.1
80	HTTP	Apache 2.4.7
445	SMB	Samba
631	CUPS	1.7
3306	MySQL	Unauthorized
8080	HTTP	Jetty 8.1.7

III. Identified Vulnerabilities

1. SQL Injection

- Found in web application parameters
- Allows execution of malicious database queries

2. Cross-Site Request Forgery (CSRF)

- Found in multiple forms (login, payroll, chat)
- Allows unauthorized actions

3. Slowloris Denial of Service

- CVE: CVE-2007-6750
- Affects Apache and Jetty servers

4. Missing Security Headers

- X-Frame-Options not set
- X-Content-Type-Options not set

5. Directory Indexing Enabled

- Sensitive directories exposed

6. Exposed phpMyAdmin Interface

- Accessible without restriction

7. Outdated Software

- Apache 2.4.7
- OpenSSH 6.6.1
- Jetty 8.1.7

8. SMB Service Vulnerability

- Vulnerable to Denial of Service

Outcome

All vulnerabilities were documented with relevant technical details for further analysis.

IV. Practice Risk Assessment

Objective

To evaluate and prioritize vulnerabilities based on their severity.

CVSS-Based Risk Evaluation

Vulnerability	Likelihood	Impact	Risk Level
SQL Injection	High	High	Critical
phpMyAdmin Exposure	High	High	Critical
Slowloris DoS	High	Medium	High
CSRF	Medium	Medium	Medium
Missing Headers	Medium	Medium	Medium

Vulnerability	Likelihood	Impact	Risk Level
Directory Listing	Low	Low	Low

3x3 Risk Matrix

Impact ↓ / Likelihood →	Low	Medium	High
High Impact	Medium	High	Critical
Medium Impact	Low	Medium	High
Low Impact	Low	Low	Medium

Analysis

- Critical vulnerabilities (SQL Injection, phpMyAdmin exposure) require immediate action
- Medium risks should be addressed in short-term
- Low risks can be monitored

Outcome

Prioritized list of vulnerabilities was created to guide remediation efforts.

V. Basic Report

Executive Summary

The vulnerability assessment identified multiple critical security issues in the target system. The most severe risks include:

- SQL Injection
- Exposed phpMyAdmin interface
- Slowloris Denial of Service

These vulnerabilities could lead to **complete system compromise, data leakage, and service disruption.**

Technical Details

Key Findings

- Multiple open ports exposing services
- Web server misconfigurations
- Lack of security headers
- Presence of outdated software

Evidence

- Nmap scan output
- Nikto scan output
- Directory listings
- Web application endpoints

VI. Remediation

1. SQL Injection

- Use prepared statements
- Implement input validation

2. Security Headers

Add configuration:

Header set X-Frame-Options "DENY"

Header set X-Content-Type-Options "nosniff"

3. Disable Directory Listing

Options -Indexes

4. Secure phpMyAdmin

- Restrict access by IP
- Use strong authentication

5. Mitigate DoS Attacks

- Enable mod_reqtimeout
- Configure firewall rules

6. Update Software

- Upgrade Apache, SSH, and Jetty

7. SMB Hardening

- Disable SMB if not needed
- Apply security patches

Sources Consulted

- OWASP Top 10
- MITRE CVE Database
- Nmap Documentation
- Nikto Documentation

VII. Conclusion

The target system is highly vulnerable due to:

- Poor configuration
- Outdated services
- Exposed interfaces

Immediate remediation is required to prevent exploitation and ensure system security.